10Alytics

ACCREDITED BY THE
AMERICAN COUNCIL OF
TRAINING AND DEVELOPMENT

Tagline: "Turning enterprise risk into board-ready decisions."

ENTERPRISE RISK MANAGEMENT CASE STUDY

Facilitator: Victoria Oluyori

GRC C26-06 — Enterprise Risk Management Case Study

10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Specialization:

Enterprise Risk Management (ERM)

Business Focus:

Enterprise Risk Management for a regulated FinTech company.

Skill Outcome:

- Identify assets and classify data by sensitivity
- Assign a Risk Level
- Quantify exposure and recommend treatment

NovaPay Financial Services

A Practical Walkthrough of Enterprise Risk Management

ENTERPRISE RISK MANAGEMENT CASE STUDY

Project Learning Opportunities:

- Quantify financial exposure using SLE, ARO and ALE
- Define KRIs for ongoing monitoring

Submission

A PowerPoint presentation saved and submitted as a PDF. You should complete the task using PowerPoint slides and then convert the presentation to PDF before submission.

10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Company Introduction

Your Organization: NovaPay

Regulated financial-services companies move money and hold sensitive personal data every day.**When admin access is weak, a login flow has no safeguards, or a vendor's risk goes unassessed, the business, its customers, and its licence to operate are all exposed.**

Enterprise Risk Management (ERM) gives a risk team a repeatable way to spot these exposures — through asset classification, threat, vulnerability analysis, and structured treatment planning before they become incidents.

This case study applies ERM to one connected scenario across a regulated FinTech.

You'll step into the role of a Junior member of NovaPay's Risk Committee and work the case study end to end i.e from asset identification to treatment recommendation.



Company Snapshot

NovaPay is a Lagos-based FinTech licensed as a Payment Service Provider, moving money for individuals and small businesses every day:

Risk Appetite: NovaPay has almost no tolerance for risks that threaten customer funds, customer data, or its licence to operate. Only Low risks may be accepted without treatment.



120 Employees

Across Engineering, Compliance/Risk, Customer Support and IT & Finance.



500,000+ Wallets

Individual customer wallets, plus 8,000+ registered small-business merchants.



3 Core Teams

Engineering, Compliance/Risk, and Customer Support own day-to-day risk decisions.

10Alytics | ACTD ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

The Business Problem

Regulated FinTechs handle real money and real customer data continuously, creating constant exposure to operational and compliance risk.

Weak access controls, unmonitored login flows, and unassessed vendors can each turn into a costly incident often before anyone in the business notices.

NovaPay needs a proactive, structured risk assessment to surface this exposure before it becomes an active incident.

The Problem

Purpose: Apply a structured Enterprise Risk Management methodology to identify potential risks, support treatment decisions, and improve NovaPay's overall risk posture.

Current challenges include:

- Admin accounts with no MFA and shared passwords
- A customer login flow with no MFA or rate-limiting
- Rising complaints about unauthorised transfers
- A payment vendor with no formal security assessment
- Limited visibility into how these risks compound across systems

Your Role

You are a Junior Risk Analyst at NovaPay.

Your job is to review three risk scenarios and recommend how NovaPay should respond.

You will complete 5 tasks:

- Identify & classify assets
- Identify threats & vulnerabilities
- Recommend risk treatment
- Recommend controls
- Calculate financial exposure using SLE, ARO & ALE

Submission

A PowerPoint presentation saved and submitted as a PDF. You should complete the task using PowerPoint slides and then convert the presentation to PDF before submission.

10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Internal Memo

Internal Email from Head of Compliance

Subject: Immediate Risk Assessment Required

Dear Risk Committee,

Three items have reached my desk this week, and the CEO has asked us to act before the next board meeting: rising complaints about unauthorised transfers, unusual admin traffic on the Payment Gateway, and a formal incident notice from PaySecure Ltd, our payment vendor.

Your objectives are to:

1. Identify & classify assets
2. Identify threats & vulnerabilities
3. Recommend risk treatment
4. Recommend controls
5. Calculate financial exposure using SLE, ARO & ALE

Please bring findings the board can act on in plain, board-friendly language.

Regards,

Head of Compliance

NovaPay Financial Services

10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Project Initiative

By completing this project, you will be able to:



Asset & Data Classification

Identify NovaPay's key assets and classify the data they handle.



Threat & Vulnerability ID

Identify what could go wrong and the weaknesses that could cause the risk.



Risk Scoring & Analysis

Assess the level of risk and recommend an appropriate treatment strategy.



Controls & Financial Analysis

Recommend practical controls and calculate SLE and ALE to understand the potential financial exposure.

Case Scenario Deep-Dive

Scenario: Three connected risk areas need assessment this quarter across NovaPay's Customer Database, Mobile App login, and PaySecure vendor relationship.

- **Customer Database** — Admin accounts have no MFA; passwords are shared among IT staff; no alerting on unusual admin access. **Owner: Head of IT**.
- **Mobile App Login** — No MFA for customers; no rate-limiting on the login screen; unauthorised-transfer complaints are rising. **Owner: Head of Product.**
- **PaySecure Ltd (Vendor)**— No formal vendor security assessment has ever been done; data-sharing boundaries aren't clearly documented. **Owner: Head of Compliance.**
- **Data Classification** — Each asset holds data classified Public, Internal, Confidential or Restricted; this drives which controls apply.
- **Outcome** — You'll use this information to complete Tasks 1–5 in your Risk Assessment Worksheet.

TASK 1: Identify & Classify Assets

Identify the key assets involved in the three scenarios and classify their data as:

- *Public*
- *Internal*
- *Confidential*
- *Restricted*

N/B: *Data classification helps determine how strongly an asset should be protected.*

Asset	Data Classification	Why?
Customer Database: No MFA, shared passwords, unusual admin activity	***Confidential***	***Customer Database*** *would consist of customers personal information including their banking information which if unauthorized personal get access to it could cause significant damage to our customer. Such database should be confidential to protect our customer information.*
Mobile App: No MFA, rising unauthorised-transfer complaints	***Public***	***Mobile App*** *should be public to all customers and user for easy use and access. However, Immediate Login Authenticator should be put in place to prevent unauthorized access.*
PaySecure: No formal security assessment	***Internal***	**PaySecure** being our vendor should be internal because we both share data and in addition to this, formal security assessment should be put in place making sure PaySecure has put in place adequate measures in protecting our customers data and they are compliant with it.

10Alytics | ACTD ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

TASK 2: Identify Threats & Vulnerabilities

Remember;
Threat = *What could go wrong?*
Vulnerability = *What weakness makes it possible?*

Complete the table:

Scenario	Threat	Vulnerability
Customer Database: No MFA, shared passwords, unusual admin activity	Unauthorized access, Repudiation, Loss of data, breach of confidentiality	No sign of prior threat modeling implemented, No access and security control in place
Mobile App: No MFA, rising unauthorised-transfer complaints	Unauthorized access, loss of funds, Customers looses trust	No sign of prior threat modeling implemented, No access and security control in place
PaySecure: No formal security assessment	Loss of data, Breach of confidentiality	Weak compliance team, No compliance or audit policy in place to ensure customers data are safe and protected.

10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

TASK 3 Recommend Risk Treatment

What should NovaPay do about the risk?

Scenario	Risk Level	Recommended Treatment	Why?
Customer Database	High 80%	Mitigate	Customers database accessed internally and it is confidential doesn't mean we can avoid the access but we can put the right control in place making sure that only authorized employee who need the access to the information to perform their day to day work should hace access
Mobile App			
PaySecure			

Risk Treatment	Meaning
Avoid	Stop the activity causing the risk
Mitigate	Reduce the likelihood or impact of the risk
Transfer	Shift some or all of the risk to another party
Accept	Knowingly accept the risk

10Alytics | ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

TASK 3 Recommend Risk Treatment

What should NovaPay do about the risk?

Scenario	Risk Level	Recommended Treatment	Why?
Customer Database			
Mobile App	High 100%	Avoid	This risk is a priority risk that needs to be stopped immediately by putting in place the right control and security to protect our customers funds from theft and attackers, so that we don't end up loosing our customers to our competitors.
PaySecure			

Risk Treatment	Meaning
Avoid	Stop the activity causing the risk
Mitigate	Reduce the likelihood or impact of the risk
Transfer	Shift some or all of the risk to another party
Accept	Knowingly accept the risk

TASK 3 Recommend Risk Treatment

What should NovaPay do about the risk?

Scenario	Risk Level	Recommended Treatment	Why?
Customer Database			
Mobile App			
PaySecure	High 100%	Transfer or avoid	Partner vendor is not compliant, putting our customers at risk. We should either pause data sharing until the security assessment is complete by transferring the risk to ensure compliance is met or we stop every activities until PaySecure is formally complaint and provide every proof of comformity.

Risk Treatment	Meaning
Avoid	Stop the activity causing the risk
Mitigate	Reduce the likelihood or impact of the risk
Transfer	Shift some or all of the risk to another party
Accept	Knowingly accept the risk

10Alytics
ACTD
ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

TASK 4: Recommend Controls

What should NovaPay actually do to reduce the risk?

Recommend 1–2 practical controls for each risk.

Risk Scenario	Recommended Control 1	Recommended Control 2
Customer Database: No MFA, shared passwords, unusual admin activity	Detective Control	Corrective Control
Mobile App: No MFA, rising unauthorised-transfer complaints	Preventive Control	Detective Control
PaySecure: No formal security assessment	Detective Control	Corrective Control

TASK 5 Calculate SLE, ARO & ALE

Use the given ARO to calculate the annual loss exposure.

Scenario

A successful Customer Database breach could put ₦50,000,000 at risk.

Asset Value: ₦50,000,000

Exposure Factor: 60%

ARO: 0.5 (once every 2 years)

Use these formulas:

SLE = Asset Value × Exposure Factor

ALE = SLE × ARO

Your Task

Calculate

Calculate financial exposure using SLE, ARO & ALE

10Alytics
ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

ANSWER 5 Calculate the Financial Risk (SLE, ALE)

SLE:
Asset Value: N50,000,000
Exposure Value: 60%
= N30,000,000

ALE:
SLE: N30,000,000
ARO: 0.5
= N15,000,000

The calculated financial risk for Annual Loss Exposure based on the giving data is: **N15,000,000**

10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Thank You

Please note

When you are done with this case study:

Kindly **share your work on LinkedIn**, and don't forget to **add it to your portfolio**.

Remember to tag @10Alytics and use these #GRC #ERMWith10Alytics #GRCWith10Alytics #RiskAnalysisWith10Alytics